MÒDUL 06 · SEGURETAT INFORMÀTICA — RA1



Seguretat lògica

Qui ets i què pots fer

CFGM Sistemes Microinformàtics i Xarxes · 2n curs

Institut Puig Castellar

Joan Sánchez

EN AQUESTA SESSIÓ

Què aprendrem avui?



Autenticació i autorització

Com un sistema comprova qui ets i què tens permís de fer un cop hi has entrat.



Contrasenyes i biometria

Com crear contrasenyes robustes i quan cal recórrer a sistemes biomètrics.



Permisos i registres

Com es controlen els permisos d'accés als fitxers i per què cal registrar l'activitat del sistema.

PER COMENÇAR, UNA MICA D'HISTÒRIA

Molt abans dels ordinadors...



ELS SENTINELLES MILITARS

Quan s'acostava algú desconegut, calia dir una senya (pregunta) i respondre la contrasenya correcta per demostrar que eres del bàndol amic.



AVUI

La lògica és exactament la mateixa: el sistema ha de saber si ets “amic” (usuari autoritzat) o “enemic” (intrús) abans de deixar-te entrar.

EL CONCEPTE CLAU DE TOTA LA UNITAT

Autenticació vs. autorització



Autenticació

- Verifica QUI ets
- “Demostra que ets tu”
- Contrasenya, targeta, empremta…



Autorització

- Determina QUÈ pots fer
- “Tens permís per a això?”
- Consulta la base de dades d'autorització

Primer et cal AUTENTICAR-TE per entrar; després, el sistema AUTORITZA (o no) cada acció que vulguis fer.

UN PAS QUE SOL PASSAR DESAPERCEBUT

Identificació, autenticació i autorització

Com en un hotel: primer et identifiques (reserva), després demostres qui ets (DNI a recepció), i finalment se't autoritza (la clau que obre la teva habitació).

1. Identificació
Dius qui ets: un nom d'usuari (p. ex. nom.cognom). És la reserva de l'hotel: encara no s'ha comprovat res.

2. Autenticació
Demostres que ets tu de veritat: contrasenya, empremta, targeta... És mostrar el DNI a recepció.

3. Autorització
El sistema decideix què pots fer un cop dins. És la clau que només obre la teva habitació.

CONTROL D'ACCÉS LOCAL VS. CENTRALITZAT

Local
Cada equip gestiona els seus propis usuaris i contrasenyes (p. ex. un PC domèstic o un servidor autònom).

Centralitzat
Un servidor gestiona tots els usuaris de la xarxa (Active Directory, compte de Google...). Un sol usuari obre múltiples serveis.

FIGURA DE REFERÈNCIA

Esquema del sistema d'autenticació

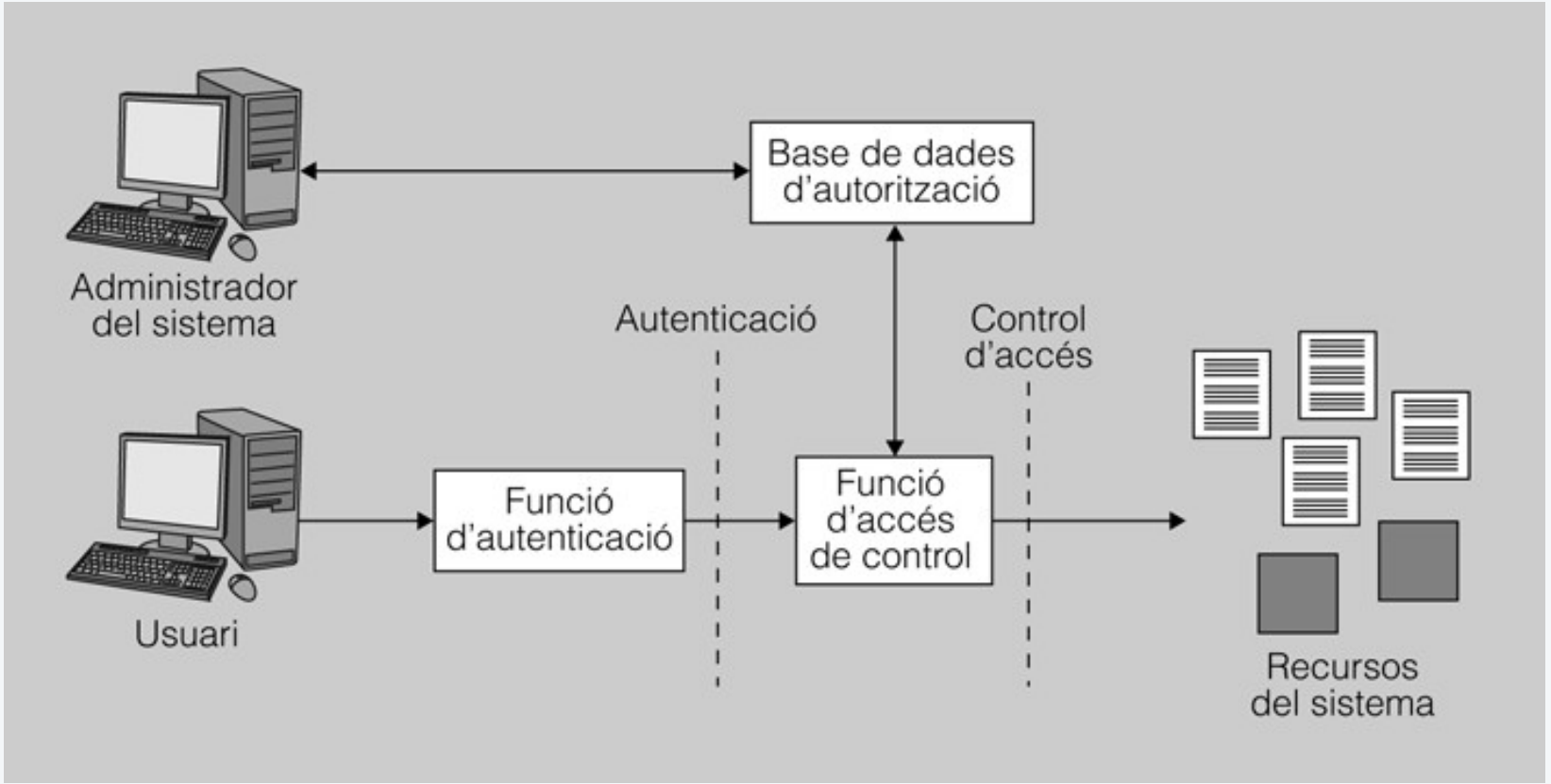


Figura 3.1 — Esquema del sistema d'autenticació per a l'entrada al sistema.

VOCABULARI CLAU

Objectes, subjectes i drets d'accés



Objecte

El recurs que té l'accés controlat: un fitxer, un directori, un registre...



Subjecte

Qui vol accedir a l'objecte: normalment, un usuari (a través d'un procés).

3 classes de subjecte

- Propietari — el creador del recurs
- Grup — usuaris amb privilegis compartits
- Altres — la resta d'usuaris del sistema

5 drets d'accés possibles

Lectura · Escriptura · Execució · Esborrament · Creació

CONTROL D'ACCÉS DISCRECIONAL (DAC)

La matriu de control d'accés

Files = subjectes. Columnes = objectes. Cada cel·la indica els drets que té aquell subjecte sobre aquell objecte.

Subjecte	/home/albert	/home/berta	/etc/passwd
Albert	Lectura, escriptura, cd	—	Lectura
Berta	—	Lectura, escriptura, cd	Lectura
Carme	Lectura, escriptura, cd	Lectura, escriptura, cd	Lectura, escriptura

Llistes de control d'accés (ACL)

Es descompon la matriu per columnes: cada objecte porta la llista de qui hi pot accedir. Windows funciona així.

Capacitats

Es descompon la matriu per files: cada subjecte porta la llista del que pot fer. Linux/UNIX combinen ambdós sistemes.

HO SABIES?

Un mal ús de contrasenyes pot fer molt mal



Any 2002

Una periodista es va fer famosa per aconseguir accés al compte de correu de Saddam Hussein.



Sense pirateria

No li van caldre grans coneixements tècnics. El mal ús de les contrasenyes és una de les 10 amenaces més habituals.

POLÍTICA DE CONTRASENYES

Febles vs. robustes



Febles

- Menys de 10 caràcters
- Una paraula de diccionari
- Nom de familiar, mascota...
- Un patró: 1234, qwerty...



Robustes

- Majúscules i minúscules
- Text + números + alfanumèrics
- Mínim 10 caràcters
- Sense relació amb dades personals

TRUC PRÀCTIC

Robustes... i fàcils de recordar

1. Pensa una frase fàcil de recordar

“Això és una manera de recordar una contrasenya”

2. Agafa la inicial de cada paraula

A · é · u · m · d · r · u · c

3. Canvia “una” per “1” i afegeix un símbol final

Ae1MdR1c!

Resultat: una contrasenya de 9 caràcters, amb majúscules, minúscules, números i símbols, i que tu pots reconstruir mentalment en 2 segons.

MATEMÀTICA (I POLÍTICA) DE LES CONTRASENYES

La longitud importa més que la complexitat

8 caràcters, només minúscules (26 símbols):
$26^8 \approx 209$ milions de combinacions possibles
8 caràcters amb majúscules i minúscules (52 símbols):
$52^8 \approx 53{,}5$ bilions de combinacions possibles

Cada caràcter addicional MULTIPLICA les combinacions: allargar la contrasenya és més eficaç que complicar-la.

Tiempo que tarda un hacker en descifrar tu contraseña en 2025
Hardware: 12 x RTX 5090 | Hash de contraseña: bcrypt (10)

Número de caracteres	Solo números	Solo minúsculas	Mayúsculas y minúsculas	Números + mayús + minús	Números + letras + símbolos
4	Al instante	Al instante	Al instante	Al instante	Al instante
5	Al instante	Al instante	57 minutos	2 horas	4 horas
6	Al instante	46 minutos	2 días	6 días	2 semanas
7	Al instante	20 horas	4 meses	1 año	2 años
8	Al instante	3 semanas	15 años	62 años	164 años
9	2 horas	2 años	791 años	3000 años	11 000 años
10	1 día	40 años	41 mil años	238 mil años	803 000 años
11	1 semana	1000 años	2 millones de años	14 millones de años	56 millones de años
12	3 meses	27 000 años	111 millones de años	917 millones de años	3 mil millones de años
13	3 años	705 000 años	5 mil millones de años	56 mil millones de años	275 mil millones de años
14	28 años	18 millones de años	300 mil millones de años	3 billones de años	19 billones de años
15	284 años	477 millones de años	15 billones de años	218 billones de años	1 cuatrillón de años
16	2000 años	12 mil millones de años	812 billones de años	13 mil billones de años	944 mil billones de años
17	28 000 años	322 mil millones de años	42 mil billones de años	840 mil billones de años	6 sextillones de años
18	284 000 años	8 billones de años	2 trillones de años	52 trillones de años	463 cuatrillones de años

La longitud és el factor que més pesa en la fortalesa real d'una contrasenya.

CADUCITAT, BLOQUEIG I HISTORIAL: EL CONSELL HA CANVIAT

Els experts (SANS Institute) ja NO recomanen forçar canvis periòdics sense motiu: obliga a triar contrasenyes previsibles (Estiu2024! → Estiu2025!...).
Bloqueig de compte després de diversos intents fallits, i historial de contrasenyes (no permetre repetir les últimes X), continuen sent útils.

SOTA EL CAPÓ

Emmagatzematge de contrasenyes: hash i sal

Un sistema segur mai desa la contrasenya en text pla: en desa un HASH (una empremta irreversible) barrejat amb una SAL aleatòria (en anglès, salt), per evitar que dues contrasenyes iguals generin el mateix resultat.

/etc/shadow (Linux)

```
joan:$6$aB3dK9fZ$Qw8..(hash SHA-512).. :19723:0:99999:7:::

$6 = algorisme (SHA-512)     ·     aB3dK9fZ = sal aleatòria     ·     la resta = resultat del hash
```

A Windows

Els hashos es desen al fitxer SAM amb l'algorisme NTLM. Eines com Ophcrack poden extreure'ls si el disc no està xifrat amb BitLocker.

Els camps de /etc/shadow (separats per ":")

Valor	Significat
`joan`	Nom d'usuari
`$6$aB3dK9fZ$...`	Contrasenya xifrada (algorisme + sal + hash)
`19723`	Dies des de l'1/1/1970 del darrer canvi
`0`	Dies mínims abans de poder tornar-la a canviar
`99999`	Dies màxims abans que calgui canviar-la
`7`	Dies d'avís abans que caduqui
`(buits)`	Inactivitat, caducitat del compte i un camp reservat

SOTA EL CAPÓ

Identificant l'algorisme pel prefix del hash

El format de /etc/shadow sempre segueix el mateix patró. El primer camp després del nom d'usuari identifica, amb un prefix curt, quin algorisme de hash s'ha fet servir.

```
usuari:$algorisme$salt$hash:

john:$y$j9T$xEHXv4J4altGJZT5opBR01$KemHTAsjl8TCxJazsTDWbFLQp7Hqvc0sPkZrrmpayr5
```

EL HASH USAT, SEGONS EL PREFIX

Prefix	Algorisme	Nota
`$1$`	**MD5**	Obsolet, considerat feble
`$2a$ / $2y$`	**Blowfish / Bcrypt**	Utilitzat en algunes configuracions
`$5$`	**SHA-256**	Estàndard fort i intermedi
`$6$`	**SHA-512**	Àmpliament utilitzat per defecte en moltes distribucions modernes
`$y$`	**yescrypt**	Hashing de contrasenya adaptativa modern i altament segur — l'exemple d'aquí sobre

POLÍTICA DE CONTRASENYES

Una contrasenya robusta... mal protegida no serveix



Enginyeria social: l'atac més comú

Un atacant truca fent-se passar per l'administrador de sistemes i demana la contrasenya. Com que l'usuari no el coneix en persona, se la dona sense sospitar res.

Normes bàsiques de protecció

- No dir-la mai per telèfon ni per correu electrònic
- No dir-la a companys, encara que siguin superiors
- No apuntar-la mai en un paper ni un adhesiu
- Canviar-la com a mínim cada sis mesos

HO SABIES?

Tècniques d'atac... i quan surten a les notícies

Força bruta
Prova totes les combinacions possibles.

Diccionari
Prova paraules i contrasenyes comunes (p. ex. llista RockYou).

Rainbow tables
Taules de hashos precalculats per estalviar temps.

Eines reals: John the Ripper · Ophcrack · Medusa

Llista RockYou (ús educatiu): weakpass.com/wordlists/rockyou.txt

DOS CASOS REALS

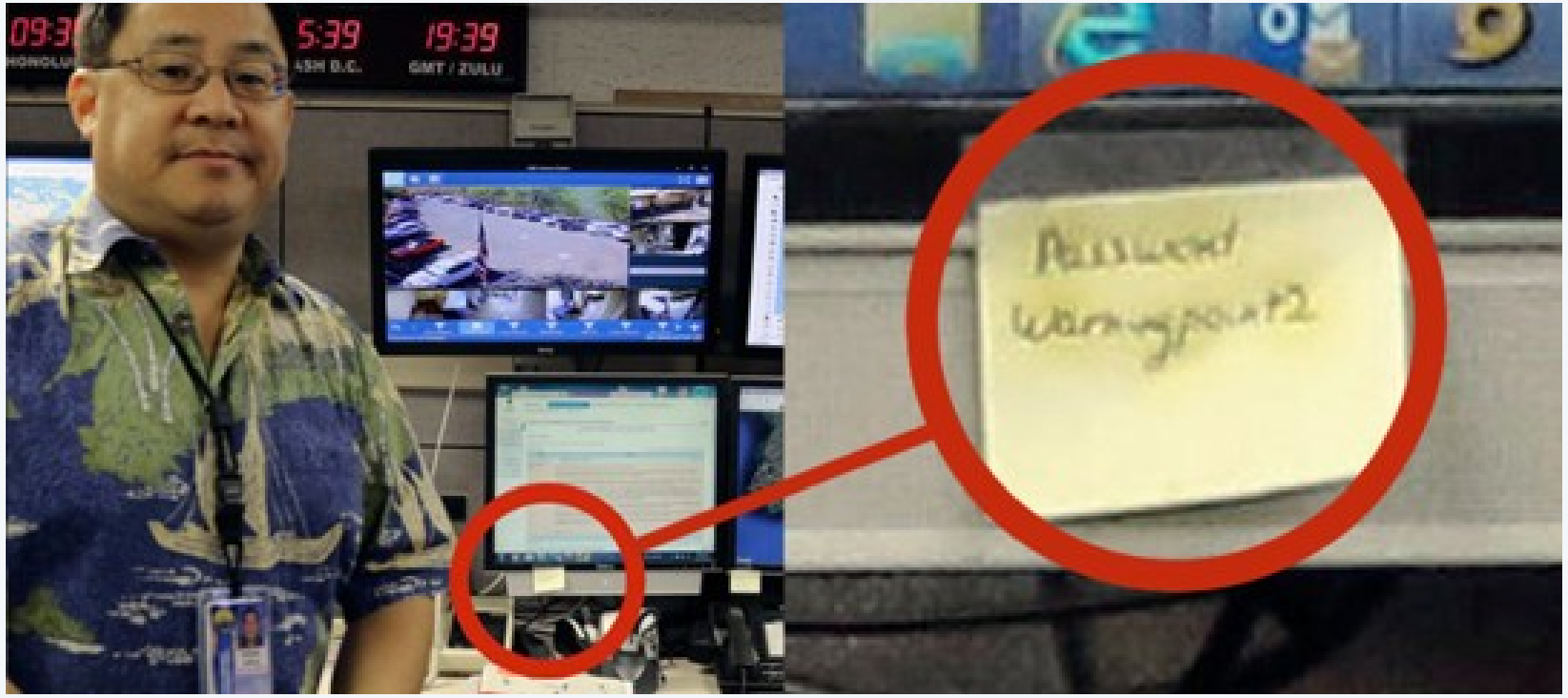
2014
Es va clonar l'empremta digital d'una ministra alemanya a partir de fotografies d'alta resolució de les seves mans en una roda de premsa.

2015 — Filtració d'Ashley Madison
Milions de contrasenyes filtrades van resultar reutilitzades d'altres serveis: un sol atac va comprometre comptes en desenes d'altres llocs web.



Les contrasenyes més utilitzades... i més fàcils d'endevinar.

Protegir les contrasenyes



Cas real (2018): un operador del centre d'emergències de Hawaii tenia la contrasenya del sistema apuntada en un post-it, ben visible al seu lloc de treball.

LA RECOMANACIÓ PRÀCTICA NÚMERO 1

Gestors de contrasenyes

Un gestor de contrasenyes genera, xifra i recorda una contrasenya diferent i robusta per a cada servei. Només cal recordar-ne una: la mestra.

Bitwarden
Codi obert i gratuït.

KeePass
Base de dades local, sense núvol.

1Password
Molt utilitzat en empreses.

LastPass
Ha patit filtracions greus: exemple del que NO ha de passar.

Sense un gestor, la gent reutilitza contrasenyes entre serveis
És exactament el motiu pel qual una filtració com la d'Ashley Madison va acabar afectant comptes de correu, banca o feina de moltes altres persones.

Sistemes biomètrics

Basats en un atribut físic

"Alguna cosa que l'usuari ÉS": empremtes, iris, retina, palmell, cara...

Basats en el comportament

"Alguna cosa que l'usuari FA": signatura, forma d'escriure... poden canviar amb el temps.

- Empremtes
- Palmell
- Retina
- Iris
- Facial

UN EXEMPLE REAL

Lector de retina: un sistema biomètric



Els sistemes biomètrics basats en la lectura de la retina són una eina molt fiable com a mesura d'autenticació.

CAP SISTEMA ÉS INFAL·LIBLE

Falsos positius i falsos negatius



Fals positiu

El sistema ACCEPTA un impostor que hauria d'haver estat denegat.



Fals negatiu

El sistema DENEGA l'accés a un usuari que hauria d'haver estat acceptat.

AUTENTICACIÓ

Els 3 factors d'autenticació



Alguna cosa que SAPS

Una contrasenya, un PIN... el més econòmic, però es pot esbrinar.



Alguna cosa que TENS

Una clau, una targeta d'accés... es pot perdre o robar.



Alguna cosa que ETS o FAS

Empremta, retina, veu... els sistemes biomètrics.

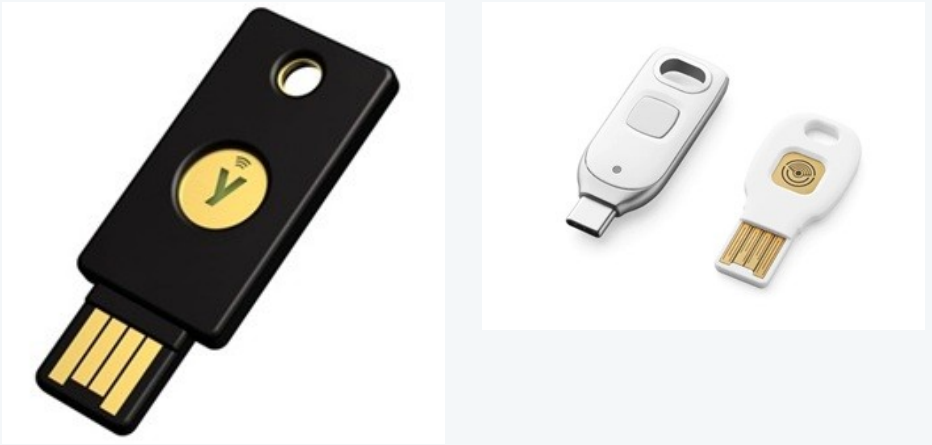
Autenticació multifactor: combina 2 o 3 factors (p. ex. contrasenya + targeta) per a un nivell de seguretat molt més alt.

EL FUTUR (JA AQUÍ)

Autenticació sense contrasenya

Els passkeys (estàndard FIDO2) eliminen la contrasenya. En el seu lloc, el dispositiu demostra la teva identitat amb criptografia de clau pública, desbloquejada amb el teu PIN, empremta o cara.

És el tercer factor d'autenticació ("alguna cosa que TENS") portat a l'extrem: connectes la clau i la toques, sense escriure res.



YubiKey i Google Titan Security Key: claus de seguretat físiques compatibles amb FIDO2.

Per què no és com una targeta d'identificació?
Una targeta clàssica repeteix sempre la mateixa dada: si te la clonen, ja la tenen. La clau del passkey mai surt del dispositiu i signa un repte diferent cada vegada, únic per a cada web: no es pot copiar ni reutilitzar en una web falsa (phishing).

AUTORITZACIÓ

Criteris per autoritzar l'accés



Rols

Segons la funció: un auditor només necessita accés de lectura.



Grups

Ex: a un institut, “alumnat” i “professorat” tenen permisos diferents.



Localització

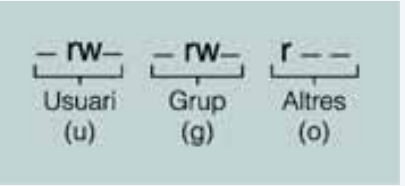
Física (des d'on ets) o lògica (des de quina IP et connectes).



Hora d'accés

Ex: un servidor només accessible de 8h a 20h.

Llegint els permisos: rwx




```
-rw-rw-r--  1  joan  profes  seguretat.doc
```

Usuari (joan)

rw- → lectura i escriptura

Grup (profes)

rw- → lectura i escriptura

Altres

r-- → només lectura

r = lectura (read) · w = escriptura (write) · x = execució (execution)

Sense permís d'execució en un directori, ningú no hi pot entrar, encara que en tingui de lectura.

A LA PRÀCTICA

Tres ordres per gestionar permisos

chmod

Canvia els permisos (rwx)

```
chmod u=rwx freebsd.pdf
```

chown

Canvia l'usuari propietari

```
chown joan qualificacions.doc
```

chgrp

Canvia el grup propietari

```
chgrp profes qualificacions.doc
```

Només l'administrador del sistema o el propietari del recurs poden fer aquests canvis.

Els 3 models d'autorització... i els privilegis

DAC — Control d'accés discrecional
(Discretionary Access Control)

El propietari del recurs decideix qui hi té accés (p. ex. permisos rwx a Linux).

MAC — Control d'accés obligatori
(Mandatory Access Control)

Una autoritat central classifica els objectes per nivell (p. ex. "top secret").

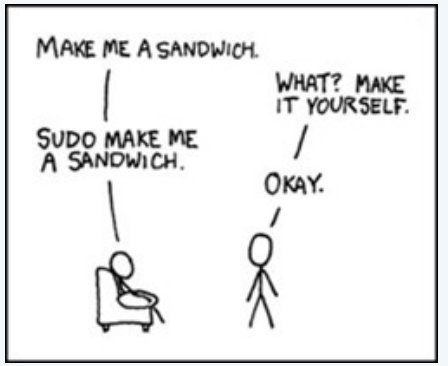
RBAC — Control d'accés basat en rols
(Role-Based Access Control)

Els permisos es lliguen al ROL, no a la persona (p. ex. metge vs. administratiu).

La pregunta clau: qui decideix? DAC → el propietari del recurs · MAC → una autoritat central (etiquetes fixes) · RBAC → el rol de l'usuari

PRIVILEGIS VS. PERMISOS

Els permisos (rwx) apliquen sobre UN recurs concret.
Els privilegis són accions globals del sistema (aturar serveis, canviar l'hora...), reservats a root/Administrador (grups sudoers / Administradors). Fins i tot Windows 11 ja incorpora una ordre sudo.



Registres, incidències i alarmes



Registres del SO

Intents d'accés, rendiment, dispositius usats, bloquejos d'usuaris...



Registres de seguretat

Antivirus, tallafocs, encaminadors, servidors intermediaris (proxies)...



Un decrement molt accentuat del rendiment pot ser un indicador que hi ha un virus o un cavall de Troia treballant en segon pla.

FIGURA DE REFERÈNCIA

Visor d'esdeveniments de Windows

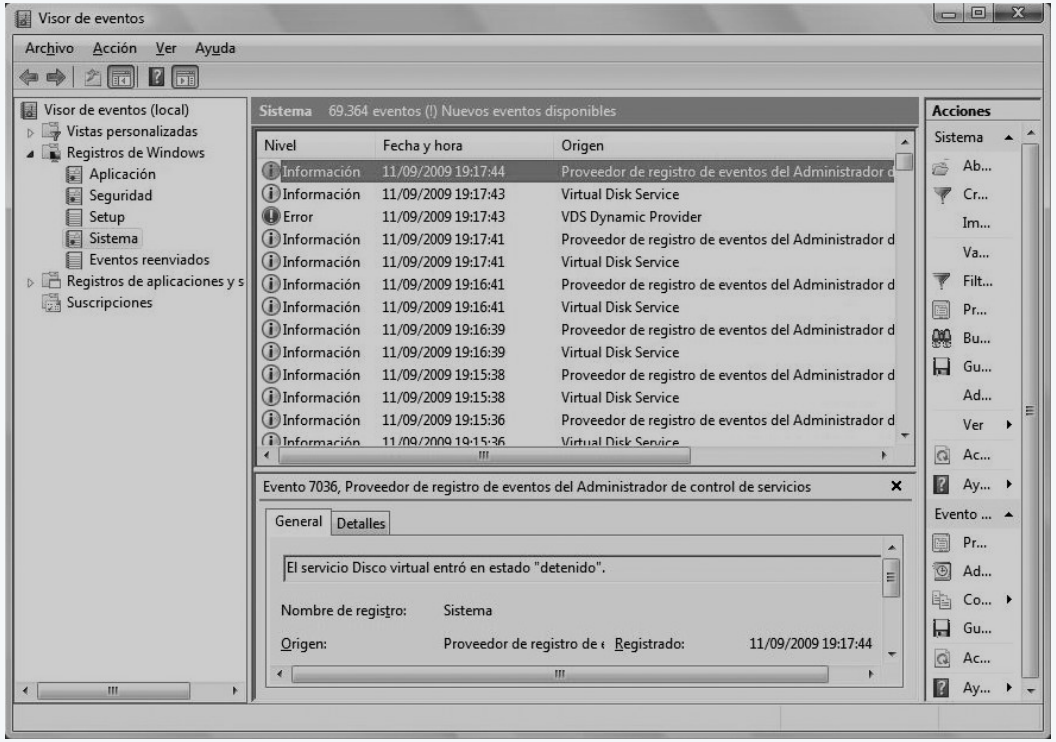




Figura 3.2 — Visor d'esdeveniments de Windows.
Els encaminadors (routers) també generen registres de seguretat rellevants.

BONES PRÀCTIQUES

Gestionar i protegir els registres

- Evitar tenir massa fonts de registres disperses
- Sincronitzar l'hora de tots els sistemes
- Utilitzar sempre el mateix format de dades
- No ometre mai l'activitat dels comptes d'administrador



Els registres també cal protegir-los

Un atacant intentarà esborrar les proves del seu pas. Sense els registres, mai sabrem que hi ha hagut un atac.

Només l'administrador i el personal de seguretat haurien de poder veure, modificar o esborrar els registres.

PER ACABAR

Idees clau d'avui



Autenticació (qui ets) i autorització (què pots fer) són conceptes diferents i complementaris.



Una contrasenya robusta és llarga, variada... i ben protegida (mai per telèfon ni escrita en un paper).



3 factors d'autenticació: el que saps, el que tens, i el que ets/fas.



Els permisos (rwx) i els registres del sistema són el dia a dia de la seguretat lògica.

ARA ÉS EL TORN VOSTRE



Crea la teva pròpia contrasenya robusta amb la tècnica de la frase.

Individualment: pensa una frase personal (que no reveleu en veu alta) i aplica'n la tècnica per generar una contrasenya. Per parelles, intercanvieu-vos consells sense revelar la frase original.

10 minuts individual + posada en comú

FONTS DEL MATERIAL

Webgrafia

Seguretat lògica

Institut Obert de Catalunya (IOC) · Material del mòdul "Seguretat informàtica" (M06), Unitat 1, apartat 3

https://ioc.xtec.cat/materials/FP/Recursos/fp_smx_m06_/web/fp_smx_m06_htmlindex/WebContent/u1/a3/continguts.html

Llicència Creative Commons BY-NC-SA · Institut Obert de Catalunya, 2011